File Upload Validation

Purpose

Specify safe handling of files submitted through HMS workflows, such as student application documents or supporting attachments, if file-upload functionality is enabled.

Upload policy

- Accept uploads only on workflows that explicitly require supporting documents. Do not expose a general-purpose upload endpoint to all users.
- Define an allowlist of permitted file formats based on institutional needs. A conservative starting allowlist may include PDF and common image formats; the project owner must confirm the final list.
- Set a maximum file size and, where applicable, maximum image dimensions. Enforce limits on the server, not only in the browser.

Validation checks

- Check the file extension, declared MIME type, and actual file signature/content. Do not trust the client-provided filename or content type alone.
- Reject empty, malformed, unsupported, oversized, or mismatched files.
- Generate a safe server-side storage name. Treat the original filename as untrusted display metadata; remove path separators and control characters.
- Prevent path traversal, executable uploads, and overwriting of existing files. Store files outside executable/public application directories unless controlled download access is required.

Malware and content safety

- Scan uploaded files with an approved malware-scanning mechanism where available before making them available to staff or other users.
- Do not execute uploaded content or render active content inline without safe transformation and appropriate browser protections.
- If scanning is unavailable, define a restricted quarantine/review process and do not treat unscanned files as trusted.

Access and privacy

- Authorize uploads against the user's role and the target application/student record.
- Authorize downloads independently; a user who can upload a document does not automatically have permission to retrieve every uploaded file.
- Use private storage and time-limited or authenticated download mechanisms. Avoid predictable public URLs.
- Apply retention and deletion rules to documents according to institutional policy.

Failure handling

- Reject an invalid upload with a specific, user-friendly reason, such as unsupported type or file too large.
- Do not save a partially received or failed file as a valid attachment.

- Record relevant upload outcomes in application logs/audit logs without logging file contents or sensitive document data.

Acceptance criteria

- The server rejects disallowed formats, spoofed file types, and files over the configured size limit.
- Stored filenames cannot control filesystem paths or overwrite unrelated files.
- Only authorized users can upload or download documents for a record.
- Failed uploads do not create broken or partially accessible attachments.

Document note: This document defines project-level requirements for the HMS utility. Confirm implementation-specific settings (such as role names, file limits, retention periods, and timeout values) against the approved project configuration before production deployment.